SDS - REQ-SE-002 요청자 신원 확인 및 상신 권한 검사

작성일 2026-10-17 · 근거: 요구사항정의서_엑셀양식_v3_1_3.xlsx (F열) · SRS 없음 · 대상: D:₩legacy-portal

1. 개요

요구사항 ID	REQ-SE-002
요구사항명	요청자 신원 확인 및 상신 권한 검사
대 / 중 / 소분류	PORTAL / Security / Identity
우선순위	High
진행현황	기획중 (비고: 현재 인증 없음 · 상신 기안자 검사 없음(특성화 테스트에 결함 후보로 표시))
요약	현재 서버는 요청 본문의 `userId` · `drafterId` 를 그대로 요청자로 믿고, 화면은 `localStorage` 에 고른 사용자를 저장할 뿐 인증이 없다. 상신은 기안자가 아니어도 된다. 로그인(세션)으로 확인한 사용자를 서버가 요청자로 쓰고, 상신을 기안자 본인으로 제한한다. API 계약(userId 를 본문으로 받음)이 바뀌므로 **재설계 단계**이며, 이 문서에서 단계적 이행 방식을 정한다. 권한 판정 한 곳(User 메서드)만 충족되어 있다.

2. 근거

SRS 없음 (엑셀 F열 · 소스만으로 분석). 아래는 요구사항정의서 F열(상세내용) 원문이다.

[개요]
요청 본문의 userId 를 그대로 믿는 구조와, 아무나 남의 문서를 상신할 수 있는 동작을 고친다.

[상세 기능 요구사항]
1) 로그인으로 확인한 사용자를 서버가 요청자로 쓰고, 요청 본문의 userId 로 다른 사람을 대신하지 못하게 한다.
2) 상신은 기안자 본인만 할 수 있게 한다.
3) 기안 생성 시 drafterId 도 로그인 사용자로 정한다.
4) 화면의 사용자 선택(localStorage 저장)을 실제 로그인으로 바꾼다.

[입력 / 출력]
- 입력: 로그인 정보, 처리 요청
- 출력: 인증된 요청자, 권한 검사 결과

[제약 조건 / 비기능 요구사항]
- 이 변경은 API 계약(userId 를 본문으로 받음)을 바꾸므로 설계 단계에서 이행 방식을 정한다.
- 권한 판정 규칙(팀장 이상)은 User 메서드 한 곳에 둔다.

[검증 기준]
- 다른 사용자 ID 를 본문에 넣어도 로그인 사용자로 처리된다.
- 기안자가 아닌 사용자의 상신이 거절된다.

[작업 대상]
legacy-portal (D:₩legacy-portal) Spring Boot 3.2 / Java 21
src₩main₩java₩kr₩hull₩portal₩approval
src₩main₩java₩kr₩hull₩portal₩user
src₩main₩resources₩static₩index.html

[Worker Settings]
- MainWorker : claude-main

- SubWorker : codex-critic
- MainWorker-SubAgent : backend-expert

3. 분석 결과

3.1 추적표

항목	요구사항(F열 문장)	SRS 근거	소스 위치	판정	비고
상세 1	로그인으로 확인한 사용자를 서버가 요청자로 쓰고, 요청 본문의 userId 로 다른 사람을 대신하지 못하게 한다.	SRS 없음	approval/ApprovalController.java:43-47, approval/dto/ProcessRequest.java:15, 27, ApprovalService.java:115, 120, pom.xml(security 의존성 없음)	미충족	인증 수단이 없고 본문 userId 를 그대로 요청자로 쓴다. 조회 API /drafts/{userId} · /inbox/{userId} 도 경로의 userId 를 그대로 신뢰한다 (ApprovalController.java:49-57).
상세 2	상신은 기안자 본인만 할 수 있게 한다.	SRS 없음	approval/Approval.java:118-133, ApprovalService.java:138-146	미충족	submit(now) 는 상태만 본다. 주석 "[보존] 요청자가 기안자인지는 보지 않는다 - 재설계 단계 결함 후보". 테스트가 현재 동작을 고정: ApprovalServiceSafetyNetTest#기안자가_아닌_사람도_상신할_수_있다.
상세 3	기안 생성 시 drafterId 도 로그인 사용자로 정한다.	SRS 없음	approval/dto/CreateApprovalRequest.java:23, 48, static/index.html:115	미충족	본문 drafterId 를 그대로 저장. 화면이 drafterId: me.id(localStorage 값)를 보낸다.
상세 4	화면의 사용자 선택(localStorage 저장)을 실제 로그인으로 바꾼다.	SRS 없음	static/index.html:90-104, user/UserController.java:9-25	미충족	사용자 목록에서 고르면 localStorage.setItem('me', ...). 비밀번호 · 세션 없음. User 엔티티에 자격 증명 컬럼 없음(User.java:21-28).
입력	로그인 정보, 처리 요청	SRS 없음	ProcessRequest.java:15	부분충족	처리 요청은 있으나 로그인 정보(자격 증명 · 세션)가 없다.
출력	인증된 요청자, 권한 검사 결과	SRS 없음	Approval.java:136-167, 189-193	부분충족	권한 검사 결과(boolean)는 있으나 인증된 요청자는 없다.
제약 1	이 변경은 API 계약(userId 를 본문으로 받음)을 바꾸므로 설계 단계에서 이행 방식을 정한다.	SRS 없음	해당 결정 문서 · 코드 없음	미충족	이 SDS 5.3절에서 단계적 이행안을 제시한다(확정은 사용자 결정).

항목	요구사항(F열 문장)	SRS 근거	소스 위치	판정	비고
제약 2	권한 판정 규칙(팀장 이상)은 User 메서드 한 곳에 둔다.	SRS 없음	`user/User.java:30, 34-37, Approval.java:192`	**충족**	결재 권한은 `User.hasApprovalAuthority()` 한 곳. 공지 게시 권한 `hasNoticePublishAuthority()`(`User.java:40-42`)는 의도적으로 분리된 별개 규칙.

3.2 판정 요약

충족 1 / 부분 충족 2 / 미충족 6 / 불일치 0 / 확인 불가 0 (총 9항목)

3.3 검증 기준 ↔ 테스트

검증 기준(F열)	테스트	현재 상태
다른 사용자 ID 를 본문에 넣어도 로그인 사용자로 처리된다.	테스트 없음	**인증 없음 - 본문 userId 로 처리됨.**
기안자가 아닌 사용자의 상신이 거절된다.	테스트 없음	**반대 동작이 고정됨: `ApprovalServiceSafetyNetTest#기안자가_아닌_사람도_상신할_수_있다`**

4. 구성 요소 설계

구성 요소	책임	설계
`pom.xml`	인증 기반	`spring-boot-starter-security` 추가(세션 기반, 비밀번호 BCrypt). 대안: 의존성 없이 `HttpSession` + 인터셉터(교육용 경량) - 10장 결정 사항
`user.User` (변경)	자격 증명 보유	컬럼 추가 `passwordHash`(VARCHAR). getter 이름은 JSON 에 나가지 않도록 `passwordHash()`(get 접두 없음) 또는 `@JsonIgnore` - `/api/users` 응답 5필드 유지. `hasApprovalAuthority()` 그대로.
`user.AuthController` (신규)	로그인 · 로그아웃 · 현재 사용자	`POST /api/auth/login`, `POST /api/auth/logout`, `GET /api/auth/me`
`user.LoginUser` (신규 애너테이션) + `LoginUserArgumentResolver`	컨트롤러에 인증된 사용자 id 주입	`@LoginUser Long requesterId` - 세션(또는 SecurityContext)에서 꺼냄
`ApprovalController` (변경)	요청자 결정	`create(@LoginUser Long requesterId, @RequestBody CreateApprovalRequest request)`: `drafterId` 를 requesterId 로 덮어 명령 생성. `process(@PathVariable Long id, @LoginUser Long requesterId, @RequestBody ProcessRequest request)`: 본문 userId 무시. URL · HTTP 메서드 · 성공 응답 그대로
`CreateApprovalRequest` · `ProcessRequest` (변경)	이행 호환	필드 `drafterId` · `userId` 는 **남겨 둔다**(구 클라이언트 JSON 호환). 신규 `toCommand(Long requesterId)` 가 로그인 사용자로 채운다. 기존 `toCommand()` 는 이행 1단계 동안 유지

구성 요소	책임	설계
`Approval` (변경)	상신 권한	신규 `boolean submit(Long requesterId, LocalDateTime now)` = 상태 DRAFT + `isDraftedBy(requesterId)`. 기존 `submit(LocalDateTime)` 는 2단계에서 제거 여부 결정
`ApprovalService` (변경)	상신 위임 변경	private `submit(Approval, Long)` 이 `approval.submit(requesterId, now)` 호출. public `processApproval(Long, Long, int, String)` · `(Long, ProcessApprovalCommand)` 시그니처 유지(userId 의미가 "인증된 요청자"로 바뀜)
`DataSeeder` (변경)	교육용 초기 계정	4명에 초기 비밀번호 해시 부여(평문 비밀번호는 소스에 두지 않고 설정값 `portal.seed.initial-password` - REQ-SE-001 과 같은 원칙)

5. 인터페이스 설계

5.1 신규 엔드포인트

엔드포인트	요청	응답	오류
`POST /api/auth/login`	`{"userId": Long, "password": String}`	200 `{"id","name","email","role","dept"}` (기존 User JSON 5필드) + 세션 쿠키	401 `{"code":"LOGIN_FAILED","message":"..."}`
`POST /api/auth/logout`	-	200 빈 본문	-
`GET /api/auth/me`	-	200 User 5필드	401 미로그인

5.2 기존 엔드포인트 (URL · 메서드 · 성공 응답 유지)

엔드포인트	현재	설계 후
`POST /api/approvals`	본문 drafterId 사용	본문 drafterId 무시, 로그인 사용자로 저장. 응답 12필드 동일(drafterId = 로그인 사용자)
`POST /api/approvals/{id}/process`	본문 userId 사용, 비기안자 상신 허용	로그인 사용자로 처리. 비기안자 상신 → 403 `NOT_DRAFTER`(REQ-NF-002 형식). 미로그인 → 401
`GET /api/approvals/drafts/{userId}, /inbox/{userId}`	경로 userId 신뢰	F열 범위 밖 - 후속 과제(경로 userId ≠ 로그인 사용자면 403 권장)
`GET /api/users`	5필드	그대로(비밀번호 해시 비노출). 로그인 화면용으로 공개 유지 여부는 결정 사항

5.3 이행 방식 (F열 제약 1 - API 계약 변경)

단계	서버	화면	호환
1 병행	로그인 API 추가. 세션이 있으면 로그인 사용자 우선, 없으면 본문 userId(레거시). 설정 `portal.auth.enforced=false`	로그인 폼으로 교체, localStorage 에는 표시용 이름만	구 클라이언트 · 기존 특성화 테스트 그대로 동작
2 강제	`portal.auth.enforced=true`: 세션 없으면 401, 본문 userId · drafterId 는 무시(필드는 받아도 무해)	-	요청 JSON 형식은 그대로(필드 무시만)

단계	서버	화면	호환
3 정리	DTO 에서 userId · drafterId 제거 여부를 별도 결정(API 계약 변경 공지 후)	본문에서 userId 제거	계약 변경

```
// 예: 다른 사용자 id 를 본문에 넣어도 로그인 사용자로 처리
POST /api/approvals/15/process   (세션: 2 박팀장)
{"userId": 3, "action": 2, "reason": ""}
→ 요청자 = 2 (본문 3 무시), 감사로그 "APPROVAL APPROVE id=15 by=2"
```

6. 데이터 설계

테이블	컬럼	변경
users	password_hash VARCHAR(100)	추가(BCrypt). 기존 컬럼 id · name · email · role(1/2/3 정수) · dept 그대로
approval	-	변경 없음. status 0/1/2/3/9 정수 그대로(ApprovalStatusConverter)

6.1 상신 전이 (변경점)

현재 상태	요청자	현재 결과	설계 후
임시저장 0	기안자	→ 상신 1	→ 상신 1
임시저장 0	기안자 아님	→ 상신 1	상태 0 유지, 403 NOT_DRAFTER
그 외	누구든	무시	409(REQ-NF-002)

7. 처리 흐름

단계	처리
1 인증	세션 → @LoginUser 요청자 id (없으면 1단계: 본문 userId / 2단계: 401)
2 조회 가드	결재 · 요청자 조회(없음 → REQ-NF-002 404)
3 권한 가드	상신: 기안자 본인 / 승인 · 반려: 지정 결재자 + User.hasApprovalAuthority() / 취소: 기안자 본인
4 상태 변경 → 저장 → 메일 → 감사로그	기존 순서 그대로, 감사로그 by= 는 인증된 요청자

8. 예외 · 경계 처리

경우	현재	설계	레거시 보존 여부
본문 userId ≠ 로그인 사용자	본문 userId 로 처리	로그인 사용자로 처리(본문 무시)	변경(재설계)
비기안자 상신	상신됨	403	변경(재설계)
미로그인 요청	해당 없음	1단계 레거시 동작 / 2단계 401	1단계 보존
기안자 미지정(null) 문서 상신	상신됨	403(isDraftedBy 가 null 이면 false)	변경(재설계)
승인 · 반려 권한(팀장 이상)	User.hasApprovalAuthority()	그대로	보존
취소의 기안자 검사	있음(Approval.java:161)	그대로, 요청자만 인증 사용자로	보존

9. 검증 설계

검증 기준	테스트(신규 제안)
다른 사용자 ID 를 본문에 넣어도 로그인 사용자로 처리된다.	`AuthenticatedRequesterTest#본문에_다른_사용자_id를_넣어도_로그인_사용자로_처리된다`
기안자가 아닌 사용자의 상신이 거절된다.	`AuthenticatedRequesterTest#기안자가_아닌_사용자의_상신은_403으로_거절된다`

```
@Test void 본문에_다른_사용자_id를_넣어도_로그인_사용자로_처리된다()
@Test void 기안자가_아닌_사용자의_상신은_403으로_거절된다()
@Test void 기안_생성의_drafterId는_로그인_사용자로_정해진다()
@Test void 로그인하지_않고_처리하면_401이_온다()          // 2단계
@Test void 비밀번호가_틀리면_로그인이_실패한다()
@Test void 사용자_목록_응답에_비밀번호_해시가_나가지_않는다()

// 예: 변수는 영어
MockHttpSession teamLeaderSession = login(TEAM_LEADER_ID, initialPassword);
mockMvc.perform(post("/api/approvals/" + approvalId + "/process").session(teamLeaderSession)
        .contentType(MediaType.APPLICATION_JSON).content("{\"userId\":3,\"action\":2}"))
    .andExpect(status().isOk());
assertThat(output.getOut()).contains("APPROVAL APPROVE id=" + approvalId + " by=" + TEAM_LEADER_ID);
```

기대값이 바뀌는 기존 특성화 테스트: `ApprovalServiceSafetyNetTest#기안자가_아닌_사람도_상신할_수_있다`(결함 후보로 표시된 테스트). 2단계(강제)에서는 세션 없이 MockMvc 를 호출하는 `ApprovalControllerTest` · `RequirementAcceptanceTest` 도 영향 - 별도 커밋 + diff 제시 + 사용자 승인 후 변경(CLAUDE.md 특성화 테스트 규칙).

10. 검토 의견 · 후속 과제

구분	내용
보존 대상	URL · HTTP 메서드, 요청 JSON 필드 구성(이행 1~2단계 동안 userId · drafterId 필드 유지), 성공 응답 형식, DB 저장값(status · role 정수), 서비스 public 시그니처, 권한 판정 규칙(팀장 이상) 위치, 저장 → 메일 → 감사로그 순서.
개선 대상	요청 본문 신원 신뢰 · 비기안자 상신 허용 · localStorage 가짜 로그인. **관찰 가능 동작과 API 계약을 바꾸므로 리팩토링이 아닌 재설계 단계**에서 5.3절 단계로 진행.
결정 필요	① Spring Security 도입 vs 경량 세션 인터셉터, ② 2단계 강제 시점, ③ `/api/users` 공개 범위, ④ 3단계에서 DTO 필드 제거 여부.
후속 과제	`/drafts/{userId}` · `/inbox/{userId}` 의 타인 조회 차단(F열 범위 밖, 같은 신원 문제).
연계 요구사항	REQ-NF-002(403 · 401 오류 형식), REQ-NF-003(drafterId · userId 필수 검증은 이행 1단계까지만 의미).